

Informed Consent – User Study “Ontwikkeling van een gebruiksvriendelijke threat modeling tool gebaseerd op fortunately/unfortunately methode”

Titel studie: Evaluatie van threat tree modeling tool

Onderzoeker: *Mika Gielkens*

Contact: *mika.gielkens@student.uhasselt.be*

Doel van het onderzoek

U wordt uitgenodigd om deel te nemen aan een studie die onderzoekt hoe softwaregebruikers security- en AI-risicoscenario's analyseren met behulp van een “Fortunately–Unfortunately”-model. Uw deelname helpt ons om de bruikbaarheid, helderheid en efficiëntie van de software te evalueren en te verbeteren.

Wat houdt deelname in?

Als u deelneemt:

- Voert u enkele praktische scenario-taken uit binnen de software.
- Evalueert u de software via een korte vragenlijst.
- De totale duur bedraagt ongeveer **NOG WAT TE TESTEN ADHV TREE GROOTTE**.

Uw deelname is volledig vrijwillig.

Risico's en ongemakken

Het onderzoek brengt **geen bekende risico's** met zich mee. U kunt op elk moment pauzeren of stoppen zonder gevolgen.

Privacy & vertrouwelijkheid

- Alle verzamelde gegevens worden **anoniem** verwerkt.
- Er worden **geen persoonsgegevens** (zoals naam, e-mail of IP-adres) gekoppeld aan uw antwoorden.

- Uw scherm zal worden opgenomen zodat dit later kan teruggekeken worden ten behoeve van het onderzoek. Deze opname zal ook live worden gevolgd door de masterstudent.
 - Uw gegevens worden uitsluitend gebruikt voor onderzoeksdoeleinden en niet gedeeld met derden buiten het onderzoeksteam.
-

Vrijwillige deelname & recht om te stoppen

Uw deelname is vrijwillig.

U mag op elk moment:

- verdere deelname weigeren, of
- het onderzoek stopzetten

...zonder dat u hiervoor een reden moet opgeven.

Gebruik van resultaten

De resultaten kunnen worden gebruikt in:

- onderzoeksrapporten
- academische publicaties
- interne evaluaties

Alle data blijven echter volledig **geanonimiseerd**.

Toestemming

Door hieronder akkoord te gaan, bevestigt u dat:

- u de informatie hierboven hebt gelezen,
- u begrijpt wat deelname inhoudt,
- uw deelname volledig vrijwillig is, en
- u toestemming geeft om uw anonieme gegevens te gebruiken voor dit onderzoek.

☐ Ik ga akkoord met deelname aan deze studie.

Story 1

Je werkt binnen een softwareteam dat bezig is met het uitwerken van een securitymodel voor een -inlog- en authenticatiesysteem. Een deel van het team heeft al een begin gemaakt aan een *Fortunately–Unfortunately*-model.

De *Fortunately–Unfortunately*-methode komt oorspronkelijk uit improvisatietheater. Het is een techniek waarbij een verhaal zich afwisselend positief en negatief ontwikkelt. Elke nieuwe stap begint met “Fortunately...” (gelukkig/positieve tegenmaatregel) of “Unfortunately...” (helaas/risico’s) en verandert zo het verloop van het verhaal. Dit zorgt ervoor dat gebruikers verschillende scenario’s verkennen en onverwachte wendingen ontdekken. → example

- “*We willen een veilige IT-infrastructuur onderhouden.*” (fortunate)
- “*Unfortunately, er zijn cyberdreigingen en kwetsbaarheden.*”
- “*Fortunately, we kunnen firewalls en detectiesystemen inzetten.*”
- “*Unfortunately, deze systemen kunnen falen of verkeerd geconfigureerd zijn.*”

In de context van dit onderzoek zijn er nog een paar definities toegevoegd aan de unfortunately en fortunately nodes:

- Een unfortunately waar een branch op eindigt → Een weakness van de software
- Een unfortunately dat niet op het einde van een branch staat en nog niet volledig klaar is → Further investigation
- Een fortunately node dat niet op het einde van een branch staat en nog niet volledig klaar is → Assumption to verify
- Een fortunately node dat op het einde van een branch is en klaar is → Verified assumption

Het model is echter nog onvolledig en sommige delen moeten aangevuld of herbekeken worden. Het is jouw taak om het bestaande model verder te verkennen, aan te vullen en te verfijnen.

Bij het controleren van de tree merk je dat er nog een *unfortunate* ontbreekt: een weakness/risico dat nog niet in het model is opgenomen, namelijk “*Sommige werknemers weigeren wachtwoordmanagers te gebruiken*”. Voeg dit negatieve scenario toe onder de node “*Uitrol van wachtwoordmanager verbetert gebruiksgemak*”. Omdat deze tak nu voltooid is, moet de laatste node als een *assumption* worden gemarkeerd. Zorg dat dit duidelijk is voor je teamgenoten.

Heeft het team al nagedacht over authenticatieprovider? Zo niet, bekijk de tree en vul deze aan. Het is mogelijk om de volgende nodes aan te vullen:

1. Fortunately: *"Externe authenticatieprovider toegevoegd voor SSO-compatibiliteit"*
2. Unfortunately: *"Provider-storingsen kunnen alle werknemers buitensluiten"*
3. Fortunately: *"Team richt on-prem fallback-authenticatieserver in"*

Nadien vraagt je teamlead naar een korte statusupdate: om een inschatting te maken van de benodigde tijd, wilt de teamlead weten welke aannames er in het model zitten, welke problemen nog niet opgelost zijn, en hoeveel ervan nog verdere opvolging nodig hebben. Het kan zijn dat er wat tijdsnood is, rangschik de weaknesses op basis van dangerrating.

Tot slot moeten de verantwoordelijkheden verdeeld worden binnen het team. Selecteer daarom twee elementen in het model die volgens jou klaar zijn voor implementatie, en licht aan je teamgenoten toe waarom en hoe deze geïmplementeerd moeten worden.

→ Hierna een user experience questionair

Story 2

Je zit in een softwareteam dat werkt aan een AI-systeem om fraude te detecteren. Er is al een begin gemaakt met een *Fortunately–Unfortunately*-model, maar het is nog niet compleet en sommige onderdelen moeten verder uitgewerkt worden.

Voor je begint aan het verder uitwerken van de tree, wil je verkennen hoever ze voorlopig al staan. Hiervoor is het nuttig om te weten wat de voorlopige weaknesses en assumptions zijn die de teamgenoten al hebben gevonden, maar ook welke nodes al onderzocht zijn maar nog verder onderzocht moeten worden. Omdat je efficiënt wilt werken begin je natuurlijk met de gevaarlijkste weakness.

Tijdens je verkenning van de gevaarlijkste weakness merk je dat er nog iets ontbreekt — namelijk *‘Toegangscontrole toegevoegd om zichtbaarheid van verklaringen te beperken’*. Zonder dit kan, zoals al aangehaald in de tree, er *“gevoelige modellogica aan interne medewerkers”* gelekt worden. Voeg deze nog toe aan de correcte node. Als deze branch nu eindigt op een *fortunately* node, mag deze laatste node als een assumption gezien worden. Zorg dat dit duidelijk is voor je collega's.

Je ziet nog een branch dat je wilt bespreken met je collega's in de volgende vergadering. In de branch zit namelijk een absurde veronderstelling. Buiten dat het absurd is, is dit zelfs nog niet eens een *fortunately*. Om deze branch duidelijk te bespreken, noteer je het verloop van de opeenvolgende nodes tot en met de node *‘Junior teamleden besluiten alle servers uit te schakelen om fraude te stoppen’*.

Daarnaast is het nuttig om te bekijken wat er gebeurt als we het model simpelweg afstemmen om minder false negatives te hebben. Dit noteren in de tree, maakt het mogelijk om hierover te brainstormen binnen het team. Als dit nog niet in het model staat, kan je het toevoegen met de volgende structuur:

1. Fortunately: *"Model afgestemd om gemiste fraude te verminderen"*
2. Unfortunately: *"Het terugdringen van false negatives leidt tot meer false positives"*
3. Fortunately: *"Risicogebaseerde scoring helpt om urgente en laag-risico waarschuwingen te onderscheiden"*

→ Hierna een user experience questionnaire

Open vragen

1. Wat vond je de nuttigste feature van de uitgebreidere software?
2. Welke onderdelen van de geteste tree software zouden volgens jou verbeterd kunnen worden?
3. Heb je suggesties om features op een andere manier aan te pakken of een feature die nog nuttig kan zijn om de user experience te verbeteren?
4. In welke software vond je het makkelijker om een scenario te analyseren?
Waarom?
5. Welke versie zou je in een echte situatie verkiezen en waarom?